FALHAS DE IDENTIFICAÇÃO E AUTENTICAÇÃO (OWASP A07): CONCEITO,

IMPACTOS, DETECÇÃO E BOAS PRÁTICAS DE MITIGAÇÃO

Diego de Azevedo
Enzo Macedo Grande Pousa
Filipe Amancio da Silva
Gilberto Ricardo Bonatti
Lucas Ferreira de Morais
Silvestre Fernandes

1 INTRODUÇÃO

A autenticação é o processo de verificar que um indivíduo, entidade ou sistema é de fato quem alega ser, por meio da validação de um ou mais autenticadores, como senhas, tokens de segurança ou fatores biométricos. Quando esse processo apresenta defeitos de projeto ou de implementação, um atacante pode assumir a identidade de outro usuário, comprometendo a confidencialidade, a integridade e a disponibilidade das informações protegidas. Esse conjunto de fragilidades é catalogado pela Open Worldwide Application Security Project (OWASP) na categoria A07:2025 – Identification and Authentication Failures (Falhas de Identificação e Autenticação).

A OWASP mantém, desde 2003, o documento Top 10, que consolida os dez riscos de segurança mais críticos para aplicações web a partir da análise de dados coletados junto a organizações de todo o mundo. A categoria de falhas de autenticação figura de forma recorrente nessas edições — apareceu como Broken Authentication na segunda posição em 2017 e permaneceu entre os riscos mais relevantes nas edições seguintes —, o que evidencia a persistência do problema ao longo dos anos e a dificuldade das organizações em erradicá-lo.

O presente artigo tem como objetivo apresentar, de forma fundamentada, o conceito da vulnerabilidade de falhas de identificação e autenticação, discutir seus impactos sobre o negócio e as aplicações, descrever as principais formas de detecção e, por fim, reunir as boas práticas de mitigação recomendadas pela

OWASP. A justificativa para o estudo reside no fato de que a autenticação constitui a primeira linha de defesa de qualquer aplicação: uma vez comprometida, todas as

demais camadas de controle de acesso tornam-se ineficazes. A metodologia adotada é a pesquisa bibliográfica, apoiada essencialmente na documentação técnica oficial da OWASP, em especial no OWASP Top 10 e na série OWASP Cheat Sheet Series.

2 CONCEITO DA VULNERABILIDADE

A categoria A07 agrupa todas as fraquezas relacionadas à confirmação da identidade do usuário, à gestão de suas credenciais e ao controle de suas sessões. Segundo a OWASP, a confirmação da identidade, a autenticação e a gestão de sessão são fundamentais para proteger contra ataques relacionados à autenticação, e a aplicação é vulnerável sempre que permite ataques automatizados, credenciais previamente vazadas, senhas fracas ou processos frágeis de recuperação de conta. Em outras palavras, não se trata de uma única falha, mas de um conjunto de deficiências que, isoladas ou combinadas, permitem que um atacante se passe por um usuário legítimo.

Para compreender o alcance da categoria, é útil separar as falhas em três domínios interligados: as falhas relacionadas às credenciais, as falhas no ciclo de vida da autenticação e as falhas na gestão de sessão. Os itens a seguir sintetizam as situações mais comuns descritas pela OWASP em que uma aplicação deve ser considerada vulnerável.

a) Falhas relacionadas a credenciais e senhas:

• Permitir ataques automatizados de força bruta, nos quais múltiplas senhas de um dicionário são testadas contra uma única conta, sem qualquer mecanismo de contenção.

• Permitir ataques de preenchimento de credenciais (credential stuffing), que reutilizam pares de usuário e senha obtidos no vazamento de outros sites. • Permitir o uso de senhas fracas, padrão ou bem conhecidas, como "Password1"

ou "admin/admin".

• Armazenar senhas em texto puro, cifradas de forma reversível ou protegidas por funções de hash fracas e rápidas, como MD5 ou SHA-1.

b) Falhas no processo de autenticação e recuperação de conta:

• Utilizar processos de recuperação de credenciais frágeis, como perguntas de segurança de resposta previsível, que não atendem às diretrizes de identidade digital.

• Expor identificadores de sessão na URL ou exibir mensagens de erro que revelam a existência de uma conta (enumeração de usuários).

• Ausência ou implementação inadequada de autenticação multifator (MFA).

c) Falhas na gestão de sessão:

• Reutilizar o identificador de sessão após o login, em vez de gerar um novo, abrindo caminho para ataques de fixação de sessão (session fixation). • Não invalidar corretamente os identificadores de sessão e os tokens após o logout ou após um período de inatividade.

• Gerar identificadores de sessão previsíveis ou com baixa entropia, permitindo que sejam adivinhados por força bruta.

Do ponto de vista de padronização, a OWASP correlaciona a categoria A07 a um conjunto de fraquezas comuns catalogadas como Common Weakness Enumeration (CWE). Entre as mais representativas estão a CWE-297 (Verificação inadequada de certificado com incompatibilidade de host), a CWE-287 (Autenticação inadequada) e a CWE-384 (Fixação de sessão). Essa correspondência com o CWE reforça que se trata de fraquezas bem conhecidas e documentadas, para as quais já existem contramedidas consolidadas.

Cabe destacar que, na edição de 2021, essa categoria recebeu a

denominação de *Identification and Authentication Failures*, ampliando o escopo anterior de *Broken Authentication* para incluir de forma explícita as falhas de identificação — ou seja, a etapa em que o sistema estabelece quem é o sujeito antes mesmo de autenticá-lo.

3 IMPACTOS NO NEGÓCIO E NA APLICAÇÃO

O impacto direto da exploração de uma falha de autenticação é o comprometimento de contas de usuários. Uma vez que o atacante consegue se passar por um usuário legítimo, ele passa a operar com todos os privilégios daquela identidade. Quando a conta comprometida pertence a um administrador, o impacto se estende ao controle total da aplicação, com possibilidade de acesso, alteração e destruição de dados de todos os demais usuários.

A OWASP observa que a autenticação é frequentemente o alvo de escolha dos atacantes justamente porque representa a porta de entrada para os demais ativos. Além do acesso indevido a dados sensíveis, as consequências abrangem a possibilidade de fraudes financeiras, o roubo de identidade, a lavagem de dinheiro e a divulgação não autorizada de informações protegidas por legislação. No contexto brasileiro, esse último ponto assume relevância adicional em razão da Lei Geral de Proteção de Dados Pessoais (LGPD), que impõe às organizações o dever de adotar medidas de segurança aptas a proteger os dados pessoais e prevê sanções administrativas em caso de incidentes decorrentes de proteção insuficiente.

Os impactos podem ser organizados em quatro dimensões complementares, descritas a seguir.

- **Impacto técnico:** tomada de contas (account takeover), escalonamento de privilégios, sequestro de sessão e uso da conta comprometida como ponto de apoio para atacar outros componentes internos da infraestrutura.
- **Impacto financeiro:** perdas diretas por fraude e transações não autorizadas, além de custos com resposta a incidentes, investigação forense, notificação de titulares e eventual indenização a usuários afetados.
- **Impacto legal e regulatório:** exposição a sanções previstas na LGPD e em normas setoriais, bem como a possibilidade de litígios movidos por titulares

de dados cujas informações foram expostas.

• **Impacto reputacional:** perda de confiança de clientes e parceiros, dano à imagem da marca e vantagem competitiva reduzida, efeitos que frequentemente superam, no longo prazo, o prejuízo financeiro imediato.

É importante ressaltar que a gravidade do impacto é proporcional à criticidade da aplicação e à sensibilidade dos dados que ela manipula. Uma falha de autenticação em um sistema bancário, de saúde ou de governo tem potencial de dano muito superior ao de uma falha equivalente em uma aplicação de baixo risco, o que deve orientar a priorização dos investimentos em segurança.

4 FORMAS DE DETECÇÃO

A detecção de falhas de autenticação combina abordagens preventivas, aplicadas durante o desenvolvimento, com abordagens reativas, voltadas ao monitoramento da aplicação em produção. Ambas são complementares e devem ser integradas ao ciclo de vida de desenvolvimento seguro.

4.1 Detecção durante o desenvolvimento e os testes

Nessa fase, o objetivo é identificar as fraquezas antes que o software chegue ao ambiente de produção. As principais técnicas são:

• **Revisão de código (SAST):** análise estática do código-fonte em busca de senhas armazenadas em texto puro, uso de algoritmos de hash fracos, comparação de senhas sem funções seguras e ausência de regeneração de sessão após o login.

• **Testes dinâmicos (DAST) e teste de intrusão:** exercício da aplicação em execução, tentando ataques de força bruta, credential stuffing, fixação de sessão e enumeração de usuários, de modo a verificar se os controles de contenção respondem como esperado.

• **Verificação de conformidade com o ASVS:** uso do OWASP Application Security Verification Standard como lista de requisitos de autenticação a

serem checados, item a item, durante a homologação.

• **Verificação de senhas vazadas:** confronto das senhas escolhidas pelos usuários contra bases de senhas comprometidas, como o serviço Pwned Passwords, tanto no cadastro quanto na detecção proativa de contas em risco.

4.2 Detecção em produção por monitoramento

Em ambiente de produção, a detecção depende de registro (logging) e monitoramento adequados dos eventos de autenticação. A OWASP recomenda registrar e revisar todas as falhas de login, todas as falhas de senha e todos os bloqueios de conta. A partir desses registros, é possível identificar padrões característicos de ataque, tais como:

• Grande volume de tentativas de login malsucedidas contra uma mesma conta, indicativo de força bruta.

• Tentativas de login isoladas contra um grande número de contas distintas, indicativo de password spraying.

• Requisições sequenciais com diferentes identificadores de sessão a partir de um mesmo endereço IP, indicativo de tentativa de adivinhação de sessão. • Mudança abrupta de endereço IP, User-Agent ou geolocalização no meio de uma sessão já estabelecida, indicativo de sequestro de sessão.

Esses registros alimentam sistemas de detecção e resposta e podem acionar contramedidas automáticas, como o bloqueio temporário do endereço IP ofensor ou a exigência de reautenticação. Projetos como o OWASP AppSensor propõem justamente a incorporação de pontos de detecção de intrusão dentro da própria aplicação, aproveitando o conhecimento do contexto de negócio para reconhecer comportamentos anômalos.

5 BOAS PRÁTICAS DE MITIGAÇÃO

As medidas de mitigação recomendadas pela OWASP podem ser agrupadas em quatro eixos: proteção das credenciais, defesa contra ataques automatizados, gestão segura de sessões e recuperação segura de contas. A seguir, cada eixo é detalhado com base na OWASP Cheat Sheet Series.

5.1 Armazenamento e política de senhas

A regra fundamental é que senhas nunca devem ser armazenadas em texto puro. Em vez disso, devem ser protegidas por algoritmos de hash modernos, lentos

e adaptativos. A OWASP recomenda o uso do Argon2id como primeira escolha, com uma configuração mínima de 19 MiB de memória, contagem de iterações igual a 2 e grau de paralelismo igual a 1; na sua ausência, recomendam-se o scrypt, o bcrypt (com fator de trabalho mínimo de 10, para sistemas legados) ou o PBKDF2 (quando houver exigência de conformidade FIPS-140).

Dois conceitos são centrais nesse eixo. O primeiro é o sal (salt), uma cadeia única e aleatória adicionada a cada senha antes do hash, que impede o uso de tabelas de consulta pré-computadas, como as rainbow tables, e obriga o atacante a quebrar cada hash individualmente. O segundo é o fator de trabalho (work factor), que controla o número de iterações do algoritmo e, portanto, o custo computacional de cada verificação; ele pode ser elevado ao longo do tempo, à medida que o hardware se torna mais rápido. Como boa prática complementar de política de senhas, a OWASP recomenda:

• Exigir comprimento mínimo — pelo menos 8 caracteres quando há MFA e ao menos 15 caracteres quando não há — e permitir senhas longas, de até 64 caracteres ou mais, para acomodar frases-senha.

• Permitir todos os caracteres, inclusive Unicode e espaços, sem impor regras de composição obrigatória de maiúsculas, números ou símbolos. • Bloquear senhas comuns e previamente vazadas, comparando-as com listas de senhas comprometidas.

• Evitar a troca periódica e arbitrária de senhas; a rotação deve ser exigida

apenas diante de indício de comprometimento.

• Comparar hashes de senha por meio de funções seguras, que retornem em tempo constante, protegendo contra ataques de temporização (timing attacks).

5.2 Defesa contra ataques automatizados

A autenticação multifator (MFA) é, de longe, a defesa mais eficaz contra a maioria dos ataques relacionados a senhas. A OWASP cita análise da Microsoft segundo a qual a MFA teria evitado *99,9% dos comprometimentos de conta*. Por

isso, deve ser implementada sempre que possível. Além da MFA, recomendam-se os seguintes controles, aplicados em profundidade:

• **Bloqueio de conta (account lockout):** impedir novas tentativas de login por um período após um número determinado de falhas, associando o contador à conta e não apenas ao endereço IP, com atenção para não permitir que o próprio mecanismo seja usado para negar serviço a usuários legítimos.

• **Limitação de taxa (login throttling):** restringir o número de tentativas em uma janela de tempo, eventualmente com atraso exponencial a cada falha. • **CAPTCHA:** utilizado como controle de defesa em profundidade, preferencialmente exigido apenas após algumas tentativas malsucedidas, para preservar a experiência do usuário.

• **Mensagens de erro genéricas:** responder sempre com uma mensagem padronizada, como "Usuário ou senha inválidos", independentemente de o usuário existir ou não, a fim de impedir a enumeração de contas. 5.3 Gestão segura de sessões

Após a autenticação, o identificador de sessão passa a equivaler, na prática, à credencial do usuário, de modo que sua proteção é essencial. As principais recomendações são:

• Gerar identificadores de sessão com pelo menos 64 bits de entropia, por meio

de um gerador de números pseudoaleatórios criptograficamente seguro (CSPRNG), tornando-os imprevisíveis.

• Regenerar o identificador de sessão sempre que houver mudança de nível de privilégio, especialmente logo após o login, prevenindo ataques de fixação de sessão.

• Transmitir o identificador exclusivamente por cookies protegidos pelos atributos *Secure*, *HttpOnly* e *SameSite*, garantindo confidencialidade e resistência a XSS e CSRF.

• Definir tempos de expiração de sessão — tanto por inatividade (idle timeout) quanto absoluto — e invalidar a sessão no servidor tanto na expiração quanto no logout explícito.

• Nunca armazenar tokens de sessão ou credenciais em localStorage ou sessionStorage, pois são acessíveis a qualquer script da origem e, portanto, expostos a XSS.

5.4 Recuperação segura de contas

O fluxo de recuperação de senha é um alvo frequente, pois um processo frágil anula todas as demais proteções. A OWASP recomenda evitar perguntas de segurança de resposta previsível e adotar mecanismos baseados em token único e temporário, enviado a um canal previamente verificado. As mensagens devem ser genéricas — por exemplo, "Se este endereço estiver em nossa base, enviaremos um e-mail" — para não revelar quais contas existem, e a operação deve exigir reautenticação após eventos de risco, como redefinição de senha ou alteração de e-mail cadastrado.

6 CONSIDERAÇÕES FINAIS

As falhas de identificação e autenticação, catalogadas na categoria A07 do OWASP Top 10, representam um risco persistente e de alto impacto para aplicações web. Por comprometerem a primeira linha de defesa — a confirmação da identidade

do usuário —, essas falhas têm o potencial de neutralizar todos os demais controles de segurança, resultando em tomada de contas, vazamento de dados sensíveis, fraudes e sanções regulatórias.

Ao longo deste artigo, verificou-se que a vulnerabilidade não decorre de um defeito único, mas de um conjunto de fraquezas que abrange o armazenamento de senhas, a resistência a ataques automatizados, a gestão de sessões e a recuperação de contas. Verificou-se, igualmente, que para cada uma dessas frentes já existem contramedidas consolidadas e documentadas pela OWASP, com destaque para o armazenamento de senhas com algoritmos de hash modernos como o Argon2id, a adoção da autenticação multifator, a geração de identificadores

de sessão com entropia adequada e o uso correto dos atributos de segurança dos cookies.

Conclui-se que a mitigação eficaz das falhas de autenticação depende menos da descoberta de técnicas inéditas e mais da aplicação disciplinada de boas práticas já conhecidas, integradas ao ciclo de vida de desenvolvimento seguro e apoiadas por monitoramento contínuo em produção. A demonstração prática que acompanha este trabalho ilustra justamente essa abordagem, ao contrastar uma implementação vulnerável de autenticação com a sua versão corrigida segundo as recomendações da OWASP.

REFERÊNCIAS

OWASP. **OWASP Top 10:2021 – A07:2021 Identification and Authentication Failures**. [S. l.]: OWASP Foundation, 2021. Disponível em: https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/. Acesso em: 18 set. 2026.

OWASP. **OWASP Top Ten**. [S. l.]: OWASP Foundation, 2025. Disponível em: https://owasp.org/www-project-top-ten/. Acesso em: 18 set. 2026.

OWASP. **Authentication Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **Password Storage Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **Session Management Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet .html. Acesso em: 18 set. 2026.

OWASP. **Forgot Password Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **Credential Stuffing Prevention Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Credential_Stuffing_Prevention_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **Multifactor Authentication Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em:

https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **Choosing and Using Security Questions Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Choosing_and_Using_Security_Questions_Cheat_Sheet.html. Acesso em: 18 set. 2026.

OWASP. **JSON Web Token Cheat Sheet**. In: OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, 2025. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/JSON_Web_Token_Cheat_Sheet.html. Acesso em: 18 set. 2026.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD)**. Brasília, DF: Presidência da República, 2018. Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 18 set. 2026.